

AWS IAM

SAA-C03 exam-ready reference

This version removes the fuzzy parts and keeps the evaluation rules that matter in exam questions.

Use this guide to decide, not to memorize slogans. The exam rewards service selection based on constraints, not analogies.

- The exam is mostly about evaluation order: identity policy, resource policy, permissions boundary, session policy, SCP, and explicit deny.
- Use the right identity model: user, group, role, root, or federated identity.
- Most wrong answers exploit one mistake: confusing a ceiling with a grant.

1. IAM Fundamentals

IAM is about identities and policies. Users, groups, roles, and root solve different problems.

Identity	What it is	Credentials	Exam cue
IAM user	Long-term human or application identity	Access keys or password	Use sparingly; best for named users only
IAM group	Collection of users	None	Used to share policies across users
IAM role	Temporary identity assumed by a trusted principal	Temporary STS credentials	Best for AWS services and cross-account access
Root user	Account owner	Email/password plus MFA	Never for daily work

Core rule: only identity-based policies and resource-based policies can grant permissions. Boundaries, SCPs, and session policies only set ceilings. For same-account access, a resource-based policy can be enough on its own; for cross-account access, the trust and identity sides both matter.

2. Policy Evaluation Logic

This is the page that wins or loses the exam. Keep the sequence in your head and ignore the noise.

Step	Question AWS asks	Result if the answer is no
1	Did the request authenticate?	Deny
2	Is there an explicit Deny anywhere?	Deny immediately
3	Do the applicable grant policies allow it?	Implicit deny
4	Do ceilings also allow it? (boundary, session policy, SCP)	Deny if any ceiling blocks it
5	If cross-account or resource policy is involved, does the resource policy allow it?	Deny
6	Does a same-account resource policy grant it directly?	Allow if the resource policy is sufficient

Remember: explicit deny always wins. Default state is deny. An allow only matters if no higher-level guardrail blocks it.

Nuance that shows up on harder questions: resource-based policies can grant access directly for same-account access. For cross-account access, the resource policy and the caller's identity side both matter. The safest exam shortcut is still to check explicit deny first, then check every applicable ceiling.

3. Policy Conditions and Permission Boundaries

Conditions are filters. Permission boundaries are ceilings. Neither one is a grant by itself.

Condition key	Typical use
aws:SourceIp	Allow or deny based on client IP
aws:RequestedRegion	Limit actions to a Region
aws:MultiFactorAuthPresent	Require MFA
aws:PrincipalTag / aws:ResourceTag	ABAC with tags
s3:prefix	Scope S3 access to a prefix

Boundary fact	Exam-safe wording
What it does	Sets the maximum permissions an IAM user or role can have
What it does not do	It does not grant permissions by itself
Effective result	Identity policy AND boundary
Best clue	The question says 'prevent privilege escalation' or 'delegate policy management safely'

4. SCPs and Session Policies

Both are ceilings. SCPs are organizational guardrails. Session policies are temporary per-session guardrails.

Policy type	Where it applies	What it does	What it does not do
SCP	AWS Organizations root / OU / account	Sets the maximum permissions for member accounts	Does not grant permissions
Session policy	One STS session	Scopes down a temporary session	Does not modify the role

SCP fact: SCPs do not affect the management account. They do affect member accounts, including the member account root user. Service-linked roles are also exempt.

Session policy fact: a session policy is passed when assuming a role or creating a federated session. The effective permissions are the intersection of the role permissions and the session policy.

5. STS and Federation

STS issues temporary credentials. Federation answers the question 'how did the user get there in the first place?'

Mechanism	Best use	Exam cue
AssumeRole	Temporary access to another role	Cross-account access, service access, or temporary elevation
AssumeRoleWithSAML	Workforce SSO from an enterprise IdP	SAML 2.0 / AD FS / corporate directory
AssumeRoleWithWebId entity	Web or mobile app identity federation	Cognito or other OpenID Connect identity provider
GetSessionToken	Temporary session for IAM user	Less common; user needs temporary credentials
GetCallerIdentity	Identify the caller	Troubleshooting; does not grant access

Federation shortcut: Identity Center is the modern central workforce SSO answer across multiple AWS accounts. If the question explicitly describes direct federation from an external IdP, use SAML 2.0 for workforce users or web identity for apps and social identity providers.

6. Credential Types and Roles for Services

The exam likes to ask which credential type belongs to which scenario, and whether a service should use a role instead of hardcoded keys.

Credential type	When to use it
Long-term access key	Only when you must support an IAM user and cannot use a role
Temporary role credentials	Best default for AWS services and cross-account access
Root credentials	Initial setup, billing, or emergency recovery only
MFA	Always a good answer when the question mentions human sign-in security

Service pattern	Correct AWS identity choice
EC2 needs to reach S3	IAM role via instance profile
Lambda needs to call DynamoDB	Execution role
ECS task needs to call Secrets Manager	Task role
AWS service needs to act on your behalf	Role, not an IAM user

Exam trap: do not use hardcoded access keys for an AWS service. If the question says 'an EC2 instance needs access', the correct answer is almost always an IAM role attached to the instance profile.

7. Access Analyzer, Policy Simulator, and CloudTrail

These three services answer different questions: what is exposed, what would happen, and what actually happened.

Service	Best question it answers	Exam cue
IAM Access Analyzer	Is this resource exposed outside my trust zone?	Findings for external access and unused access
Policy Simulator	Will this policy combination allow the request?	Test before deployment
CloudTrail	What action actually occurred?	Audit and investigation

Access Analyzer fact: it can generate a least-privilege policy from CloudTrail activity. It is not a logger; CloudTrail is the logger.

8. Identity Center

Identity Center is the modern answer for workforce SSO across many AWS accounts and apps.

Component	Meaning
Identity source	Where users come from: built-in directory, AD, or an external IdP
Permission set	Reusable access template such as ReadOnly or AdminAccess
AWS account assignment	Which account and permission set a user receives

Exam cue: if the problem says one login for multiple AWS accounts and a central permission model, the answer is Identity Center. If it describes direct federation from an external IdP, use SAML 2.0 or web identity, depending on whether the users are workforce users or app users.

9. Master Keyword Map

If the question says...	Think...
maximum permissions for a role or user	Permissions boundary
organizational guardrail across accounts	SCP
temporary session-only reduction	Session policy
enterprise SSO into AWS	Identity Center or SAML
web/mobile login from an app	AssumeRoleWithWebIdentity / Cognito
need to verify what happened	CloudTrail
need to test a permission before using it	Policy Simulator
need to see external sharing risk	Access Analyzer

10. Top Exam Traps and Quick Reference

Trap 1: a permissions boundary does not grant permissions. It only caps what the identity policy can grant.

Trap 2: an SCP does not grant permissions. It sets the maximum for member accounts in the organization.

Trap 3: a session policy is temporary and session-specific. It does not permanently modify the role.

Trap 4: explicit deny wins. If you remember only one rule, remember this one.

Quick formula	Use this
Single policy decision	Deny by default, allow only if explicitly allowed
With boundary	Identity policy AND boundary
With session policy	Role permissions AND session policy
With SCP	Identity policy AND SCP must both allow